

Response to the Reviewers — Submission 11 (ROCAP)

We thank the meta-reviewer and the three reviewers for their careful and constructive reading. The revision addresses every point raised; where we retain a modeling choice, we now argue it explicitly in the paper and acknowledge the alternative. The main changes are: a corrected UFO-C grounding of the Attack Plan definition (§3.1), a restructured tactic-dependency model with no cross-level relations (Fig. 2), redrawn instance diagrams with proper individuals and no stereotypes (Figs. 4–5), a remodeled Business/Supporting Asset relation, a documented co-design and CQ-derivation methodology (§4.1), a white-box walkthrough of CQ7 (§4.4, Listings 1–2), and the removal of the PAPO reuse claim and of all "seamless" claims. Below we respond point by point.

Meta-review

We redrew the instance diagrams (Figs. 4–5) with unambiguous individual names and without stereotypes, and restructured Fig. 2 around first-order event types. There is also, in the online repository, all class diagrams of the ROCAP ontology (Visual Paradigm Project and pictures of the diagrams), alongside the OWL and Prolog artifacts; the Data Availability note points to it.

Reviewer 1

In Section 2.2, the paper states that CVE provides identifiers for vulnerabilities, while CWE classifies the underlying software weaknesses that vulnerabilities instantiate. I am not convinced that this is ontologically correct. The statement that “a vulnerability (CVE) is a specific, real-world instance” is misleading. The vulnerability of the software running on my computer is a particular vulnerability. A particular named CVE is not that particular vulnerability. The CVE sense of “vulnerability” should have been treated as a type of vulnerability. For example, a currently executing program may bear a vulnerability that instantiates a type of vulnerability enumerated in the CVE system. This paper missed an opportunity to shed light on this terminological and ontological confusion.

The reviewer is correct. §2.2 and footnote 9 now treat a CVE entry as a *vulnerability type*, bound to a particular product and version, specializing a CWE *weakness type*; the actual vulnerability is the concrete disposition borne by a deployed system, which instantiates a CVE-catalogued type. Fig. 3 models this accordingly: CVE Vulnerability and CWE Weakness appear as types instantiated by COVER::Vulnerability through ROSE::Vulnerability Type.

In Section 2.3, the paper claims that what remains missing is “the middle ground: a plan defined as a structured event specification” between an attack plan and an attack execution. I do not understand how a plan defined as a structured event specification is a middle ground between an attack plan and an attack execution. This should be clarified.

We agree the phrasing conflated the plan with the specification. The gap statement now reads: what is unrepresented is "the plan itself—the intention committing the attacker to a specific, structured course of action—which gives content to the goal and provides the blueprint against which executions can be compared." The plan is the intention; the specification is what it refers to.

In Section 3.1, I am not convinced that the paper's use of UFO-C is correct. The paper states that "UFO-C treats a plan as the pairing of a UFO-C::Closed Intention—the agent's commitment to instantiate a specific UFO-B::Complex Event Type whose temporal parts are related by UFO-B::Historical Dependence, stronger than accidental but weaker than causality." This at least needs breadcrumbs that allow the reader to follow the conclusion. The paper does not provide a reference to UFO-C sufficient to support this interpretation. My understanding is that UFO-C treats "Plan" as a synonym for "Action Universal," not as such a pairing. My understanding is also that UFO-C defines Closed Commitment, not Closed Intention, as a Commitment that is based on a Plan. The paper should provide much more precise sourcing and explanation for these claims.

The reviewer is correct on both counts. §3.1 now states first, sourced to the ODE paper (Guizzardi et al. 2008), that in UFO-C a Plan is an Action Type (originally an Action Universal). We then make the polysemy of "plan" explicit—an Action Type, or an intention to instantiate one—and adopt the intentional reading as our modeling choice, grounded in Bratman, not attributed to UFO-C. The definition is now explicit about the construction: an Attack Plan is a closed intention, i.e., an Intention (an internal commitment in UFO-C) that is also a Closed Commitment—the intersection the original sources leave implicit. It is based on a distinct Complex Action Type; Historical Dependence orders the temporal parts of the instances of that type, not the parts of the type itself. We considered renaming the concept "Attack Intention" and retain "Attack Plan" as the operative term in SOC practice, with the ambiguity now resolved at the point of definition.

The paper also states that "in UFO-C, a plan is formed by an agent on the basis of certain UFO-C::Beliefs about its environment." I am not convinced this claim is supported by the cited UFO-C paper. Since this claim is used to motivate the treatment of attack plans, it needs explicit support

The reviewer is correct that this is not spelt out there. The revised attacker-model paragraph attributes the belief-based selection of a feasible course of action to Bratman's belief–desire–intention account and presents it as our explicit, UFO-compatible assumption.

In Figure 1 and the surrounding text, I have several concerns. The text refers to an Attacker, but Attacker is not shown in the figure. Presumably every Attack Plan inheres in an Attacker. Not explaining this makes the model harder to understand than necessary.

Fixed: Attack Plan is now a «mode» characterizing ROSE::Attacker in Fig. 1, making the inherence explicit.

The sentence "We represent a socio-technical system as a set of Business Assets (UFO::Endurants, e.g. business application, customer data) that hold value for an organization" has several problems. Switching back and forth between plural and singular terms in a different font is inconsistent, distracting, and incorrect. Neither "business application" nor "customer data" itself is an instance of UFO::Endurant. The authors should use articles where they intend particulars, such as "a business application." But this also reveals another problem: "a customer data" is uncountable nonsense. Finally, the sentence is grammatically incorrect: "a set ... that hold ... and qualify as multiple ...". A clearer version would be: "We represent one socio-technical system as many instances of Business Asset that

each hold value for an organization. Every Business Asset is a UFO::Endurant and can instantiate more specific types as well, such as Business Application and Customer Data Element."

We adopted the proposed phrasing, with one amendment following from the recategorization discussed under Reviewer 3: Business Application is now a Supporting Asset, so the Business Asset examples become Business Workflow. "We represent one socio-technical system as composed of many instances of Business Asset that each hold value for an organization and therefore qualify as COVER::Objects At Risk. A Business Asset is an organizational component bearing value for the organization---every Business Asset is a UFO::Endurant and can instantiate more specific types as well, such as Business Workflow."

A similar problem occurs with "Cybersecurity Value Component (UFO::Mode, e.g. confidentiality, integrity, availability)." Confidentiality, integrity, or availability are not, themselves, instances of Cybersecurity Value Component or UFO::Mode. They appear to be specializations. More generally, there is something fishy about the notion of an individual confidentiality, integrity, or availability. Even though they are nouns, they seem to need to modify "level," which suggests that they may be assessments assigned by someone. Moreover, I disbelieve that every C, I, or A inheres in a Business Asset. An example of what I believe to be the case instead is that a health care provider is obligated to block the realization of a "disposition to be exposed" of a "patient record" that they (or the government) believe would most harm a patient. The so-called "confidentiality [level]" is that belief, which inheres in them (or the government) and is externally dependent on the type of mode called "disposition to be exposed".

We agree on the first point: Confidentiality, Integrity, and Availability now specialize Cybersecurity Value Component, and each individual component bears a graded value—addressing the "level" observation. The deeper point is an interesting one, and we understand the reviewer's interpretation; the situation is analogous to the distinction between Trust (a belief) and Trustworthiness (a property of the Trustee) (Amaral et al. 2019, 2021). We stand by our view that confidentiality, integrity, and availability are properties of Business Assets, while recognizing that the reviewer's health-care example brings out further legitimate readings. In that example, what is at stake seems to be primarily the *capacity* of the health-care provider to prevent people from exposing and tampering with the data and to guarantee its accessibility—dispositions of the surrounding system rather than of the data—of which the confidentiality *level* would be a quality grading their degree. The level can also be read, as the reviewer suggests, as a belief that is part of an assessment—analogue to risk as a quality of a risk assessment—or even as analogue to trustworthiness signals, information emitted by an entity to influence a trustor's beliefs. §3.2 now entertains this design space explicitly while stating our choice: we retain inherence in the Business Asset, its subject-relativity marked by the external dependence on the Protected Subject (Fig. 1), because our impact analysis attaches loss to the asset's value components.

The text says Supporting Assets expose COVER::Vulnerabilities" could just as easily be said more consistently as "(Choose: some or every) Supporting Asset exposes a COVER::Vulnerability". Moreover, why doesn't the diagram depict this?

Corrected. The text now says a Supporting Asset bears vulnerabilities, and derives this rather than stipulating it: Supporting Asset specializes COVER::Risk Enabler (ROSE), which the

vulnerabilities characterize. Quantification is explicit: a Supporting Asset may bear one or more vulnerabilities. The specialization is depicted in Fig. 1.

In Figure 2, I see problems with the treatment of UFO::Complex Event. How can an Attack Plan be based on a UFO Complex Event that has already happened? UFO Complex Event, itself, is a 1stOT, and ATT&CK Tactic, itself, is a 2ndOT, so it makes no sense for an UFO Complex Event to aggregate an ATT&CK Tactic, such as the one called "Privilege Escalation". Even if the word "Type" had been accidentally left off of "UFO Complex Event Type", it would still be incorrect to have its instances aggregate ATT&CK Tactic instances. Instead, instances of ATT&CK Tactic (such as the one called "Privilege Escalation") would specialize UFO Complex Event.

The reviewer is correct. The concept is now UFO-C::Complex Action Type, and no relation crosses instantiation levels: Tactics appear as first-order «event» types linked by «instantiation» to the higher-order ATT&CK::Tactic and UKC meta-tactics.

Also in Figure 2, Privilege Escalation is itself a type of UFO Event, so it makes no sense for an occurrence to be an occurrence of ATT&CK Tactic by way of UKC Get In.

Corrected, following the same principle. Since Historical Dependence holds between individual events, it is confined to the instance diagrams (Figs. 4–5). Figure 2 instead uses a defined domain relation enables between first-order event types—enables(B, A) holds when instances of A typically historically depend on some instance of B—following the pattern of defined relations in ROSE. Where a dependency targets a meta-tactic, we introduce a base event type (Keep In+formed Action) so that enables relates first-order types only.

In Figure 4, there appear to be many mistakes in the diagram of instance specifications. I believe the links labeled “characterized by” and “characterizes” are backwards.

Some meta-levels also appear to be incorrect. Some meta levels appear to be incorrect. Every instance of Supporting Asset suggests it is a type that can be multiply instantiated. For example, a Person would instantiate the Supporting Asset called "Employee". I can't tell if this is a naming issue or that the author is confused. Either way, the diagram is too difficult to interpret.

Figure 5 also appears to be off by a meta-level. For example, T1189 can be multiply instantiated, so it is a type. Gain Initial Foothold seems to be a type of Intention that can be multiply instantiated. Types do not cause types.

The diagrams were redrawn. All individuals now carry proper names that cannot be read as types (blacksuitOperator, johnDoe, zoomInstaller, workstation01, victimCorpITDepartment, fileserver01), intentions are bearer-qualified individuals (e.g., gainInitialFoothold_bs vs. gainInitialFoothold_es—distinct intentions of distinct attackers, which is precisely what CQ8 exercises), stereotypes are removed from the instance specifications, and the characterization directions are fixed.

Finally, in Listing 1, one apparent flaw is that anticipated still includes T1083 even though T1083 is already observed. If “anticipated” means “not-yet-observed expected techniques,” then this output is incorrect.

This was a transcription error not present in the code; the output shown now keeps observed and anticipated disjoint.

On the recommendation. We took the type-instance and meta-level objections as the core of the review and corrected all of them in both models and text; we hope the reviewer finds that the competency-question validation now rests on a sound model.

Reviewer 2

In particular, the paper repeatedly uses the term "seamless" to describe integration into SOC workflows, enrichment with other ontologies, and alignment with PAPO. This is not appropriate unless the authors define what seamless means and demonstrate it. Does it refer to no changes in the ontologies, no semantic conflicts, ease of implementation, reasoning interoperability, reduced analyst effort, or something else? As currently written, this reads as ambiguous and an overclaim.

We agree. The term is removed throughout; the paper now claims vocabulary alignment with industry standards to ease integration, and the PAPO reuse demonstration is deleted (see also Reviewer 3).

The practical utility for SOC analysts is stated but it is not demonstrated. The paper mentions co-design with SOC analysts and standard experts, but the process by which these experts were involved is not explained.

It is not clear how their input shaped the ontology, the competency questions, or the validation setup.

A new §4.1 documents the four-stage process and the two expert groups—SOC analysts from Gatewatcher, and information-security standardization experts including a member of the ISO/IEC JTC 1/SC 27 Luxembourg national committee—and how their input shaped the concepts (e.g., Cybersecurity Value Component, Untreated Risk) and the CQs, refined until consensus.

The introduction motivates the need for a reference ontology, but some claims need more careful framing and support. For example, the paper claims that SOC analysts need to reconstruct attack scenarios from scattered signals and that ROCAP supports seamless integration into workflows. These statements may be true in some settings, but they depend strongly on the tools, attack models, and organizational processes used in a SOC. The authors should either cite sources that support these claims or phrase them more cautiously. Similarly, the paper should clarify whether the limitation it identifies concerns ontologies specifically or attack modeling techniques more generally, since techniques such as attack trees are also used to reason about attacker knowledge and attack scenarios.

The reconstruction-from-scattered-signals claim is now supported by the systematic SOC study of Vielberth et al. The scope is clarified in the Introduction: attack trees and graphs are discussed and cited (Oliveira et al. 2025) as instance-level analytical artifacts, and the limitations we identify explicitly concern reference ontologies, not attack-modelling techniques in general.

The paper is strongest when it explains the plan/execution distinction. However, the need to represent intention as a structured specification of steps should be introduced earlier and

more explicitly. At present, the related work section later states that prior work models intention only as a motivation label rather than as structured steps, but this distinction is not sufficiently prepared in the motivation. The authors should make clearer why an attack plan must be represented not only as an intention but as an intention bound to a structured event specification.

It now opens the Introduction as the first limitation, prepared by a concrete operational example—the same phishing-based credential reuse serving either exfiltration or persistence—showing why a motivation label is insufficient and an intention bound to a structured course of action is required. Consistently with the corrected definition, the plan is the intention referring to the specification, not the specification itself.

Several modeling decisions require stronger justification. The role of attacker beliefs is discussed, but attacker capabilities appear later in the risk assessment part and are not introduced consistently in the attack-plan model.

The authors should clarify what kind of attacker model ROCAP relies on and how beliefs, capabilities, intentions, and objectives relate.

A dedicated paragraph now opens §3.1: the attacker is characterized by a COVER::Threat Capability (explicitly inherited from COVER and detailed in §3.3), Beliefs, and Intentions whose propositional content is the objective; beliefs constrain which plans are envisaged, capability which are executable, and an Attack manifests these dispositions.

The concepts of Business Asset, Supporting Asset, Cybersecurity Value Component, and value distribution should also be better explained. In particular, the statement that the value of a Supporting Asset is distributed to the Business Assets it supports is not self-evident and may be argumentative. The authors should justify this modeling choice and discuss alternatives.

§3.2 now justifies the choice and discusses the alternative: attributing value at the Business Asset level keeps the loss chain aligned with what the organization stands to lose, whereas assigning intrinsic value to each Supporting Asset—the natural alternative—would double-count value already realized there.

The adaptations to ATT&CK and the Unified Kill Chain are interesting, but the rationale for them should be better described. For example, the introduction of Keep In+formed, the treatment of Execution as internal to other tactics, and the split between Local and Remote Discovery may be reasonable, but the paper should make clearer whether these decisions are based on practitioner feedback, empirical observations from APT campaigns, limitations of existing standards, or purely ontological reasoning.

Now stated: the adaptations (Keep In+formed, Execution as internal, the Discovery split) were guided by the SOC analysts involved in the co-design, for compliance with real-world APT campaigns.

The validation should also be strengthened. Answering competency questions derived from ISO/IEC 27005 and NIST CSF is useful, but the paper should make clearer how the questions were derived, how the cybersecurity standard expert and SOC analysts contributed, and whether the questions test capabilities that existing approaches cannot provide. The reuse evaluation with PAPO also needs more substance. Showing that both ontologies can be aligned

without modification is a useful first step, but it does not by itself demonstrate "seamless" reuse. I would expect the reuse discussion to include application to another case or integrated reasoning across the enriched ontology.

§4.1 details the process of CQs derivation and ontology construction; §4.4 now details CQ7's codification and walks through the resolution on both scenarios (Listings 1–2), including the disambiguation step. CQ8 specifically test what execution-oriented models cannot provide: distinguishing identical observations by the intentions they realize as §4.4 now states. The PAPO reuse evaluation is removed.

Minor comments. Cybersecurity is consistently called a domain. The ontologies-only scope is fixed (§1). The attacker model addresses the §3.1 request. §3.2 explains the name "Cybersecurity Value Component" through its grounding in COVER::Value, as opposed to a free-standing security property. The TTP terminology is corrected to Tactics and Techniques. Attacker and Attack Plan are now visible in Fig. 1. The motivation for Keep In+formed precedes its introduction in the corresponding bullet. §5 contains no "seamless" claim. A proofreading pass was made.

Reviewer 3

There are several problems with the provided formalization and with the authors' erroneous use of UFO that they should fix. Still, they do not severely affect the central contribution, and the fixes are largely evident.

The UFO corrections are detailed under Reviewer 1 (shared items): the Plan/Closed-Intention construction, the level discipline in Fig. 2, and the instance diagrams.

The validation part also has issues. The presentation of the evaluation by CQs lacks enough detail to be useful (even considering the supporting material provided in the anonymous online repository). I strongly suggest further detailing that. Besides, the claim about reusability seems a bit far-fetched and not backed up by proper evidence. I would consider majorly revising it or even cutting it off entirely - the contribution is already good enough, introducing more controversial arguments is unnecessary.

We agree—reporting success is not informative. §4.4 now gives CQ7's Prolog codification and walks through the resolution that produces its answers, including how an additional observation collapses the ambiguity between the two candidate plans; the full traceability matrix remains in the repository. We followed the suggestion and cut the PAPO enrichment section entirely. Given the shared contributors between PAPO, COVER, ROSE, and ROCAP, we agree the independence required for that validation cannot be claimed.

*p.1: "assess the risks threatening *their* Information Communication Technology infrastructure under their protection" -> "[...] *the* [...]"*

Fixed.

p.5: "These contributions acknowledge that attacks are goal-directed, but intention is modelled as an attribute of a threat actor—a motivation label or goal category—not as a structured specification of steps."

-> Why should “intention”, in general, be modeled in terms of a series of steps? It is perfectly conceivable to understand an intention exclusively in terms of the end goal.

We agree the general reading of intention as an end goal is legitimate; the text now says so, and argues it is insufficient specifically for plan recognition, which requires a closed intention—one whose satisfaction is bound to the instantiation of a specific, structured course of action.

p.6-7: “we can formally define an Attack Plan as (i) a UFO-C::Closed Intention, held by a threat actor and constrained by its beliefs, to achieve a malicious goal by instantiating a specific UFO-B::Complex Event Type and (ii) a UFO-B::Complex Event Type whose temporal parts—individual attack steps—are related by UFO-B::Historical Dependence.”

-> This passage leads the reader to understand that an instance of Attack Plan is, simultaneously, an instance of “Intrinsic Moment” and of “Event Type”. Is this really what you want to convey? If not (as it seems to be the case) clarify that they are different entities referred to by the same term.

-> The parts of an Event Type are Event Types themselves. Thus, there are no historical dependence between them, i.e., the existence of an Event Type is not, in this case, dependent on the existence of another Event Type. The historical dependence holds between the events that instantiate such types.

Both fixed by the corrected definition: the Attack Plan is the closed intention, based on a distinct Complex Action Type, and Historical Dependence orders the temporal parts of the instances of that type.

Fig. 1:

-> The label “ATT&CK::Techni” appears to be truncated.

-> Why is there an aggregation relation from Supporting Asset to Business Asset? Is a Business Asset, in some sense, composed of Supporting Assets as parts? How?

-> In the text, you say that a Business Asset typically “depends on” Supporting Assets to realize its function. What is the nature of this dependence, and how does an aggregation relation qualify as such?

-> Since a Business Asset typically, and so not necessarily, depends on Supporting Assets, why is the minimum cardinality 1 at the Supporting Asset end? If the dependence is contingent, the cardinality should simply be *.

The label is fixed. On the relation: after discussion among the authors we agree it is not parthood. It is remodeled as supported by, a functional dependence (Guizzardi 2009): to deliver its value to the Protected Subject, a Business Asset requires instances of Supporting Asset functioning as such. The contingency is now spelled out—a Business Asset can exist without supporting assets but cannot realize its value without them—and the cardinality is accordingly *.

p.7: “Furthermore, a Business Asset typically depends on Supporting Asset(s) to realize its function for the organization.”

-> *What exactly is a Supporting Asset? Are they only physical entities (such as the servers you mention later) or could they be non-physical (e.g., operational systems, virtual machines). At least provide some examples.*

Now a role played by an Endurant—physical or not—with examples including an operating system, a virtual machine, and a deployed business application. Relatedly, we recategorized the business application, miscategorized as a Business Asset in the original draft: Business Assets are organizational components bearing value (business workflow), Supporting Assets the technical and human resources supporting them. This dissolves the reviewer's decoupling counterexample: only the supporting substrate bears technical or human vulnerabilities, so the indirection ("a Business Asset bears vulnerabilities only indirectly") now follows from the categories rather than being stipulated.

p.7: "A core design choice we made here is to decouple COVER::Value from COVER::Vulnerability; Business Assets hold COVER::Value for the organization (Cybersecurity Value Components), whereas Supporting Assets expose COVER::Vulnerabilities (e.g., unpatched software, lack of cyber awareness)."

-> *It is confusing. Supporting Assets expose vulnerabilities. What exactly does "expose" mean here?*

-> *What bears such vulnerabilities exposed by Supporting Assets?*

-> *Considering "business application" as a piece of software, it seems able to bear a vulnerability such as "unpatched software". Since you provided "business application" as Business Asset, at least some business assets would bear vulnerabilities, which hinder your decoupling approach.*

p.8: "Symmetrically, a Business Asset only exposes COVER::Vulnerabilities indirectly through its Supporting Asset(s)."

-> *It is not clear why/how this is true. You should clarify the notions of Business and Supporting Asset.*

p.8: "We assume that an Attack does not directly engage a Business Asset. Instead, it offensively engages a Supporting Asset by exploiting its COVER::Vulnerabilities"

-> *It suggests that "exposing" vulnerability in some sense is or at least requires "bearing" a vulnerability. Clarify this.*

Replaced by bears, derived from Supporting Asset specializing COVER::Risk Enabler, as detailed under Reviewer 1.

p.8: "This, together with our modeling of COVER::Vulnerability (in Section 3.3) and asset operationally causes a ROSE::Attack of certain Attack Type."

-> *Something is missing here. It sounds as your modeling of Vulnerability and Asset CAUSES an Attack!*

Rephrased: an Attack is the manifestation of the attacker's Threat Capability and Intention meeting a Vulnerability of a Supporting Asset.

p.8: “A Tactic is composed by ATT&CK::Techniques and CAPEC::Patterns; these are complementary concepts that describe offensive actions.”

-> What do you mean by "describe" here? Are Techniques and Patterns also Event Types, or are they informational entities?

Clarified in §3.2: both are event types, repeatable across occurrences, of which the ATT&CK and CAPEC catalogue entries are descriptions.

p.8: “The Attack subsequently brings about a COVER::Loss Event”

-> "brings about" relates events to situations. Actually, Fig. 1 says that Attack "causes" Loss Event.

Fixed: the Attack causes the Loss Event; the Loss Event brings about the Loss Situation, consistently with Fig. 1.

Fig. 2:

-> What is the "covers" relation?

-> Are you saying that every Complex Event Type is composed of a Tactic? The mereological relation with cardinality 1.. on the Tatic end says so.*

-> What is the relation represented by the unlabeled line between Get In and Get Out?

All removed by the restructure: Fig. 2 now contains first-order event types, «instantiation» links to the higher-order types, and the defined relation enables; there is no relation between Get In and Get Out.

p.8-9: “UKC groups Tactics into three meta-Tactics which can be considered as higher-level Attack Events”

-> Are Tactic and these meta-Tatics Events or Event Types?

Clarified: they are higher-order types that subsume ATT&CK::Tactic—a tactic such as Reconnaissance instantiates both.

p.9: “a cross-cutting Tactic that covers (or conceals) other Tactic(s)”

-> How does an Event Type cover/conceal another Event Type? Shouldn't it be instances of such Event Types that cover one another? In fact, there are several points throughout the text in which it is unclear if you are talking about Event Types or the Event instances of the mentioned types.

Reworded at the correct level: Defense Evasion is a cross-cutting Tactic whose instances serve to prevent detection by the defender; as this prevention relation targets the defensive sub-model, it lies outside the scope of Fig. 2.

Fig. 3:

-> Typically, events are the relata of causal relations. It is odd to say that events are “caused by” moments (including in UFO-B, as far as I know). Consider revising.

-> In which sense does an Agent “create” an Action? You could say that an agent participates in or performs an action, but “creates” is weird. Consider revising.

-> What is the event that grounds Untreated Risk as a Historical Role? The definition only refers to a relator. (“ROCAP introduces Untreated Risk being the COVER::Risk assessed through COVER::Risk Experience Assessment.”)

-> Also, a relation of <<characterization>> from a quantity to a relator is strange. Usually, it would originate from a moment toward something else. It needs clarification.

The relation between Intention and Action follows the UFO-C reading—an Action is a manifestation of the Intention—now made explicit. The creates relation between Attacker and Attack is reused unmodified from ROSE and read in §3.2 as the manifestation of the attacker's dispositions. Untreated Risk is now a phase, removing the need for a grounding event. Risk is corrected to a quality; as qualities can inhere in relators, the characterization towards Risk Assessment stands.

Table 1: “To which sense of plan are you referring here?”

With the §3.1 definition in place, “attack plan” in the CQs unambiguously denotes the closed intention; CQ7 accordingly matches a trace against the course of action a plan is based on, as its codification shows.

Fig. 4:

-> *Blacksuit[...]* --inheres in→ *Untreated Risk[...]*: How does a relator inhere in a quantity?

Corrected in the redrawn diagram.

Sec. 4.3:

-> There is not much value in simply reporting that your evaluation succeeded. If it was the result of processing a large amount of data, ok, you would have no choice but simply plotting the statistics. However, your case is relatively small, so it is feasible to explain the path to your results. Show here how you codified at least some of your CQs and then walk through the reasoning process that led to the retrieval of the information as you expected. One of the great advantages of ontologies is precisely their white-box nature. The more the users can understand the rationale behind the reasoning, the more confident they get, and the more useful the ontology becomes!

Fully agreed; addressed by the CQ7 walkthrough described above.

p.14: “We demonstrate this by enriching ROCAP with PAPO”

-> Where is the demonstration? How the enriched version looks like? You are making a strong claim without bringing enough evidence.

p.14: “PAPO models a Phishing Plan as a «relator»—focusing on the external, social commitments a phisher makes regarding targets and impersonations. Conversely, ROCAP models an Attack Plan as a «mode» (a Closed Intention)—focusing on the threat actor’s internal mental commitment to execute a structured sequence of multi-stage steps. Rather than a conflict, this divergence simply reflects a difference in scope and perspective. PAPO

captures the social mechanics of a campaign, while ROCAP captures the structural mechanics of multi-stage execution. Because both representations anchor cleanly into distinct, complementary layers of the same foundational UFO framework, they coexist perfectly.”

-> It does not seem such a minor compatibility issue to me. The ontologies fundamentally disagree about the nature of the most central concept of your ontology: Attack Plan. It is not just a matter of focus, but of ontological commitment. PAPO acknowledges a type of entity that ROCAP does not. It leads to several deep issues:

** If I adopt ROCAP and need to extend it with the concept of Phishing Plan, do you think that I will end up modeling Phishing Plan as a relator or a mode?*

** Do you acknowledge that, besides a Mode and a Complex Event Type, there is still a third type of entity collapsed under the term "Plan"?*

** Where should a PAPO user anchor the Phishing Plan class? Since it cannot be a subclass of Attack Plan, does it mean that a Phishing Plan is not an Attack Plan? Or does it mean that there are two distinct types of entity that we refer to as "Phishing Plan" - one that is an Attack Plan, another that is not? Or does it mean that there is another relator type, "Social Attack Plan" that is the super class of PAPO's "Phishing Plan" and should be added to ROCAP?*

** From that perspective, couldn't every ontology seamlessly align and be enriched by every other ontology? Then, wouldn't it be just a matter of taking all the top classes of one ontology and add as specializations of "Thing" in the other ontology?*

By and large, we could say that ontologies basically differ in respect to scope and perspective, since those aspects guide the way we delineate the entities in reality. The key point is choosing the suitable ones that allow us to capture the shared conceptualization of a domain. You argued that, by relying on industrial standards, your ontology would seamlessly integrate with current workflows, but it doesn't seem to be the case. Your work is good, but falls short in this respect - and, yet, this is fine!

Table 2:

-> Briefly explain what do you mean by "divergence", "refinement", and "same anchor". They may have multiple interpretations and it is not immediately obvious which one you intended to convey.

We accept the reviewer's analysis in full: the disagreement over the nature of the central concept is an ontological commitment, not a matter of focus, and the claim could not stand as made. The section, Table 2, and the claims are removed, and no "seamless" integration claim remains anywhere in the paper.

*p.14: “from established foundational ontologies (COVER, ROSE)”
-> They may be core ontologies, but certainly not foundational ones.*

Corrected to core ontologies.

We believe the revision addresses all concerns and thank the reviewers again for a set of comments that materially improved both the ontology and its presentation.